

Privacy in Internet — Cheat Sheet

Ultra-terse. Numbers match the exam question list. Four lenses to fall back on: data minimisation · unlinkability · provable vs. ad-hoc guarantee · trust model.

FOUNDATIONS & LEGAL

1 · Security vs Privacy conflicts — logging/accountability ↔ minimisation; authentication/ID ↔ anonymity; monitoring/DPI ↔ confidentiality; backups/availability ↔ right to erasure; central identity ↔ unlinkability. *CIA triad vs Unlinkability/Transparency/Intervenability.*

2 · OECD 8 Principles — Collection Limitation · Data Quality · Purpose Specification · Use Limitation · Security Safeguards · Openness · Individual Participation · Accountability.

3 · GDPR roles — Data Subject · Controller (4(7)) · Processor (4(8)) · Joint Controllers (26) · Recipient (4(9)) · Third Party (4(10)) · DPO (37–39) · Supervisory Authority (51) · Representative (27) · EDPB (68).

4 · Privacy by Design (lecture/Chow) — *Idea:* build privacy in at design stage, not only via law/PETs (GDPR Art 25). **Two strategies:** **(1) Data minimization** (“you cannot lose what you don’t have”, Art 5(1)(c)) — ask: *what data? how long? how many copies? what purpose?* · **(2) Pseudonymisation** (Art 4(5): no attribution without separate extra info; reversible ≠ anonymisation) via **encryption · hashing · masking · aggregation · indirect references/ tokenisation**. Controller measure → lower breach harm & fine (Arts 25, 32, 34).

5 · DPIA — 4 parts (Art 35(7)) — (a) description of processing + purposes · (b) necessity & proportionality · (c) risks to rights & freedoms · (d) measures to address risks.

PRIVACY-PRESERVING IDENTITY

6 · U-Prove actors/interactions — Issuer · Prover · Verifier. *Issuance* (blinded → issuer can’t relink). *Presentation* (disclose chosen attrs; tokens mutually unlinkable).

7 · U-Prove selective disclosure — token signs all attrs; per-attribute disclose/hide; hidden attrs stay committed yet signature verifies over full set; can prove predicates on hidden attrs.

8 · SSI architecture — Trust triangle: **Issuer → VC → Holder → VP → Verifier + Verifiable Data Registry** (ledger: DIDs, keys, schemas, revocation — *not* personal data). Holder controls disclosure.

9 · DID purpose — globally unique ID, no central authority; `did:method:id`; decentralisation, self-control, persistence, crypto-verifiability; resolves to DID document.

10 · Replace the CA (DPKI) — distributed ledger as public-key registry (consensus replaces CA) · Web of Trust · self-certifying IDs (id derived from key) · key-transparency logs.

11 · Verifiable Credential structure — (1) metadata (@context, id, type, issuer, dates, status/schema) · (2) claims (`CredentialSubject`) · (3) proof (signature). VP = VCs + holder proof.

12 · SSI privacy enhancements — selective disclosure · ZK/ predicate proofs (age ≥ 18) · pairwise/peer DIDs (no correlation) · no issuer “phone home” · local wallet storage · unlinkable presentations (BBS+/CL).

13 · DID document contents — id, @context, controller, **verificationMethod (public keys)**, verification relationships (authentication, assertionMethod, keyAgreement, capabilityInvocation/Delegation), **service endpoints**. No personal data.

14 · SSI adoption challenges — interoperability/standards · key mgmt & recovery · usability · network effects (chicken-egg) · governance/trust frameworks · GDPR erasure ↔ immutable ledger · revocation · scalability/cost · incentives.

EIDAS 2.0

15 · eIDAS advantages over SSI — legal certainty/effect (QES = handwritten sig) · high assurance (state-rooted ID) · mandatory mutual recognition · established trust framework (QTSPs, Trusted Lists) + liability · mandated standardisation.

16 · “verified & secure ID is essential” → for EU people — every MS must offer an **EUDI Wallet by end 2026** (use voluntary); strong state-rooted verified identity; less fraud, cross-border use, selective disclosure; safeguards: **unobservability, pseudonyms, PbD/default**.

17 · Advanced SSI features in eIDAS 2.0 — holder wallet + VCs (EAA/QEAA) · selective disclosure (basic feature) · ZK proofs (envisioned; ARF uses SD-JWT/mdoc) · combine multiple attestations · pseudonyms · unobservability · OpenID4VCI/VP.

DIFFERENTIAL PRIVACY

18 · DB privacy problem — release useful stats without exposing any individual (differencing/linkage). Good solution = utility + privacy + robust to auxiliary knowledge + composition + **provable** guarantee → DP.

19 · Local vs Global DP — *Global:* trusted curator noises outputs → less noise, better utility, trust curator. *Local:* user noises own data first → no trusted curator, more noise (Apple, RAPPOR).

20 · DP guarantee — one record’s presence barely changes output. $\Pr[M(D) \in S] \leq e^{\epsilon} \cdot \Pr[M(D') \in S]$ (+ δ). Plausible deniability vs any side knowledge; aggregate facts still learnable.

21 · Query sensitivity — $\Delta f = \max_{D, D'} \|f(D) - f(D')\|_1$ (neighbouring). Count → 1 · Sum[0, m] → m · Mean → m/n.

22 · ϵ & Laplace noise — ϵ = privacy budget; $\downarrow \epsilon \rightarrow \uparrow$ privacy, $\uparrow$ noise. **$M = f(D) + \text{Lap}(\Delta f/\epsilon)$** , scale $b = \Delta f/\epsilon$, var = $2(\Delta f/\epsilon)^2$. Noise $\propto \Delta f$, $\propto 1/\epsilon$.

WEB TRACKING & PROFILING

23 · Storage-based (client) tracking — HTTP cookies (1st/3rd-party) · Flash LSOs · HTML5 localStorage/IndexedDB · ETag/cache & favicon · HSTS supercookies · **evercookies/zombie cookies** (respawn).

24 • Cookie-less tracking — fingerprinting · IP · cache/ETag · server-side + first-party data sharing · login/hashed-email IDs · probabilistic matching · Privacy Sandbox Topics (on-device).

25 • Browser fingerprinting + defence — combine UA+fonts+screen+**canvas/WebGL/audio**+timezone → unique stateless ID. Defence: **Tor Browser (uniform)**, resistFingerprinting/Brave (randomise), reduce JS/surface, be “normal”.

26 • Search engines threaten privacy — query logs reveal interests/health/intentions · profiling & ad targeting · cross-service linkage · log de-anon (AOL 2006) · filter bubbles · gov/legal access.

27 • Predictive analytics + 3 uses — train model on historical data → predict future-outcome probability (data→features→train→predict→act). Uses: credit/fraud · healthcare risk · churn / predictive maintenance.

28 • Tracking → health/fitness/insurance — wearables (steps/HR/sleep) → health; search/purchases → conditions (Target pregnancy); **telematics** (speed, braking, mileage, time) → usage-based insurance premium. Risk: discriminatory pricing.

29 • Social bots — automated accounts mimic humans, coordinated botnets, amplify (astroturfing). *Users*: disinformation/manipulation. *Companies*: fake reviews, stock manipulation. *Govt*: election interference, polarisation.

ANONYMITY NETWORKS, LOCATION, AI ACT, ML

30 • Tor vs Mix — *Tor*: low-latency onion routing, 3-relay circuit, real-time, **no batching/cover** → weak vs global timing correlation. *Mix*: high-latency, **batch+reorder+delay+dummy traffic** → strong vs traffic analysis, unsuitable for browsing.

31 • Location threats — re-identification (**4 points ID 95%**, de Montjoye) · sensitive inferences (religion/health/politics) · stalking/burglary · profiling · surveillance · linkage de-anon.

32 • AI Act — forbidden (Art 5) — ① manipulative/subliminal · ② exploiting vulnerabilities · ③ social scoring · ④ predictive policing by profiling alone · ⑤ untargeted facial scraping · ⑥ emotion recognition (work/edu) · ⑦ biometric categorisation of sensitive traits · ⑧ real-time RBI in public for law enforcement (narrow exceptions).

33 • AI Act — high-risk (Annex III) — ① biometrics · ② critical infrastructure · ③ education/training · ④ employment/worker mgmt · ⑤ essential services (credit scoring, benefits, insurance) · ⑥ law enforcement · ⑦ migration/asylum/border · ⑧ justice & democratic processes.

34 • Why privacy in ML — models leak training data: membership inference · model inversion · memorisation/extraction (LLMs) · gradient leakage. + GDPR, fairness. Defence: DP-SGD, federated learning, secure aggregation.

35 • Federated learning — server→global model→clients train locally→send **only updates**→server aggregates (**FedAvg**)→repeat. Raw data never leaves device (minimisation, no honeypot). Caveat: updates leak → add secure aggregation + DP.